



Guía Implantación de un Sistema de Gestión de Seguridad de la Información (SGSI)

Evaluación de Riesgos

La hoja "Evaluación de Riesgos" de la planilla Guía - [Implantación SGSI - Inventario activos y Evaluación riesgos](#) se divide en dos partes.

Por un lado, la evaluación de riesgo actual; esta evaluación se realiza en base a la exposición y al impacto sobre la organización resultando en un "número de riesgo", la exposición se calcula en base a las amenazas y vulnerabilidades.

	A	B	C	D	E	F	G	H	I	J
	Grupo	Amenaza	Vulnerabilidades	Prob. Amenaza	Nivel Vulnera	Exp.	Impacto	Controles actuales	Riesgo residual actual	Tratamiento
1	Bases de datos	Acesso no autorizado * Usuario interno o externo que logra ingresar a un sistema o área restringida. * Esta amenaza puede ser lógica o física.	No hay control sobre el otorgamiento de permisos a las bases de datos de producción.	Baja	Media	Baja	Medio-Alto	Físico: las bases de datos están en datacenter con control de acceso Contratos de confidencialidad	4	
2	Bases de datos	Incumplimiento de requisitos legales, regulatorios o contractuales * Software, Hardware, servicios o personas que estén incumpliendo de alguna manera requisitos legales, regulatorios o contractuales establecidos en la empresa.		Media	Alta	Alta	Medio	las bases de datos con datos personales han sido registradas.	5	
3										

Por otro lado, tenemos el riesgo residual; esto refiere al riesgo que se obtiene de aplicar los tratamientos sugeridos para los riesgos actuales.

	A	K	L	M	N	O	P
	Grupo	Controles	Nueva Prob.	Nuevo Nivel Vul.	Nuevo Exp.	Nuevo Impacto	Riesgo Residual
1	Bases de datos				Baja		#N/A
2	Bases de datos				Baja		#N/A
3							

Descripción de campos:

Grupo: Grupo de activos a evaluar.

Amenazas: una causa potencial de un incidente indeseado, que puede dar lugar a daños a un sistema o a una organización.

Vulnerabilidades: una debilidad de un activo o de un grupo de activos que puede ser explotada por una o más amenazas.

Prob. Amenaza: probabilidad de ocurrencia de la amenaza.

Nivel Vulera.: grado de afectación de la vulnerabilidad.

Exp.: Grado de exposición; esto refleja que tan expuesto está el activo ante el "mundo" en base a las amenazas y vulnerabilidades que tiene.

Impacto: Valoración máxima asignada a Disponibilidad, Integridad o Confidencialidad dentro del grupo de activos referenciado. Pasa saber este valor se debe consultar la hoja "Inventario de Activos".

Controles actuales: Controles existentes que mitiguen la amenaza.

Riesgo residual actual: Valor asignado según la siguiente tabla, teniendo en cuenta la Exposición y el Impacto del **Índice** grupo de activos.

MATRIZ DE RIESGOS					
Exposición → Impacto	Muy baja	Baja	Media	Alta	Muy Alta
No Aplica	0	0	0	0	0
Bajo	1	2	3	4	5
Medio	2	3	4	5	6
Medio-Alto	3	4	5	6	7
Alto	4	5	6	7	8

Tratamiento: Acciones o controles sugeridos para mitigar la amenaza.

[← Inventario de activos](#)[Plan de Seguridad de la Información →](#)[Ir al Índice](#)

Etiquetas

[Gestión y auditoría de Seguridad de la Información](#)[Marco de Referencia](#)[Política Digital del Uruguay](#)[Políticas de Ciberseguridad](#)[Ciberseguridad](#)[Herramientas para organismos](#)[Política Digital del Uruguay](#)

Índice

[Introducción](#)[Objetivo y alcance](#)[El Sistema de Gestión de Seguridad de la Información \(SGSI\)](#)[Estructura de trabajo](#)[Fases de Implantación](#)[Anexo I](#)[Inventario de activos](#)[Evaluación de Riesgos](#)[Plan de Seguridad de la Información](#)[Indicadores](#)

Agencia de Gobierno Electrónico y Sociedad de la Información y del Conocimiento

[Índice](#)

Dirección: Liniers 1324 piso 4 (Montevideo, Uruguay)

Teléfono: [\(+598\) 2901 2929](tel:+59829012929)

[Contacto](#)

Horario de atención: lunes a viernes de 9:00 a 17:00 h.

gub.uy